



PROPOSAL FOR SECURITY AUDIT OF SMC, SAMBALPUR APPLICATION

VERSION 1.0

NOVEMBER 15, 2021

PRESENTED TO : STLIndia, Bhubaneswar

AUTHOR : SECUREYES

DOCUMENT HISTORY

Version	Author	Date	Approval
V1.0	Mrutunjay Sahoo	November 21, 2021	Sudip Das

This document and any revised pages are subject to document control. Please keep them up-to-date using the release notices from the distributor of the document.

TABLE OF CONTENTS

1. Executive Summary	4
1.1. Preface	4
1.2. Our Proposition	4
2. SecurEyes – A Brief Profile	4
2.1. Introduction	4
2.2. Relevant experience	5
2.3. SecurEyes Geographies	6
2.4. SecurEyes Offices & Partners	7
2.5. Testimonials.....	8
3. Project Scope And Approach.....	9
3.1. Project Scope.....	9
3.2. List Of Activities:.....	9
4. Reporting & Deliverables	10
5. Other requirements	10
6. Cost Estimates.....	11
a. Terms and conditions	11
7. annexure	12
7.1. assessment methodology – Web Application Pen Testing Methodology	12
7.1.1. Introduction	12
7.1.2. Assessment Steps.....	12
7.1.3. Detailed Steps	13

1. EXECUTIVE SUMMARY

1.1. PREFACE

The objective of Sambalpur Municipal Corporation is to provide civic services to the inhabitants of the town and extend basic facilities to the area and people which includes cleaning and sanitation work, street lights and its maintenance, supply of water, construction and maintenance of roads, drains, culverts, community centers, renovation of ponds, controlling mosquito and health hazards, regulating growth of the town in a planned manner, uplifting the status of the poor & destitute, implementing all kinds of welfare schemes of Government, taking steps to beautify the town and more provisions for convenience of the people through Market complexes, Ponds, Kalyanmandaps, Town halls, Guesthouses and such other functions to enrich the living of the people of the town.

1.2. OUR PROPOSITION

We understand that STLIndia is looking for a competent, stable, trusted, and experienced information security consulting partner to assist with meeting the objectives of this project. We strongly believe that with its technical skills, vast experiences in handling similar security audit assignments, expertise and proven industry experience, SecurEyes has the right combination to be the partner in this project.

2. SECUREYES – A BRIEF PROFILE

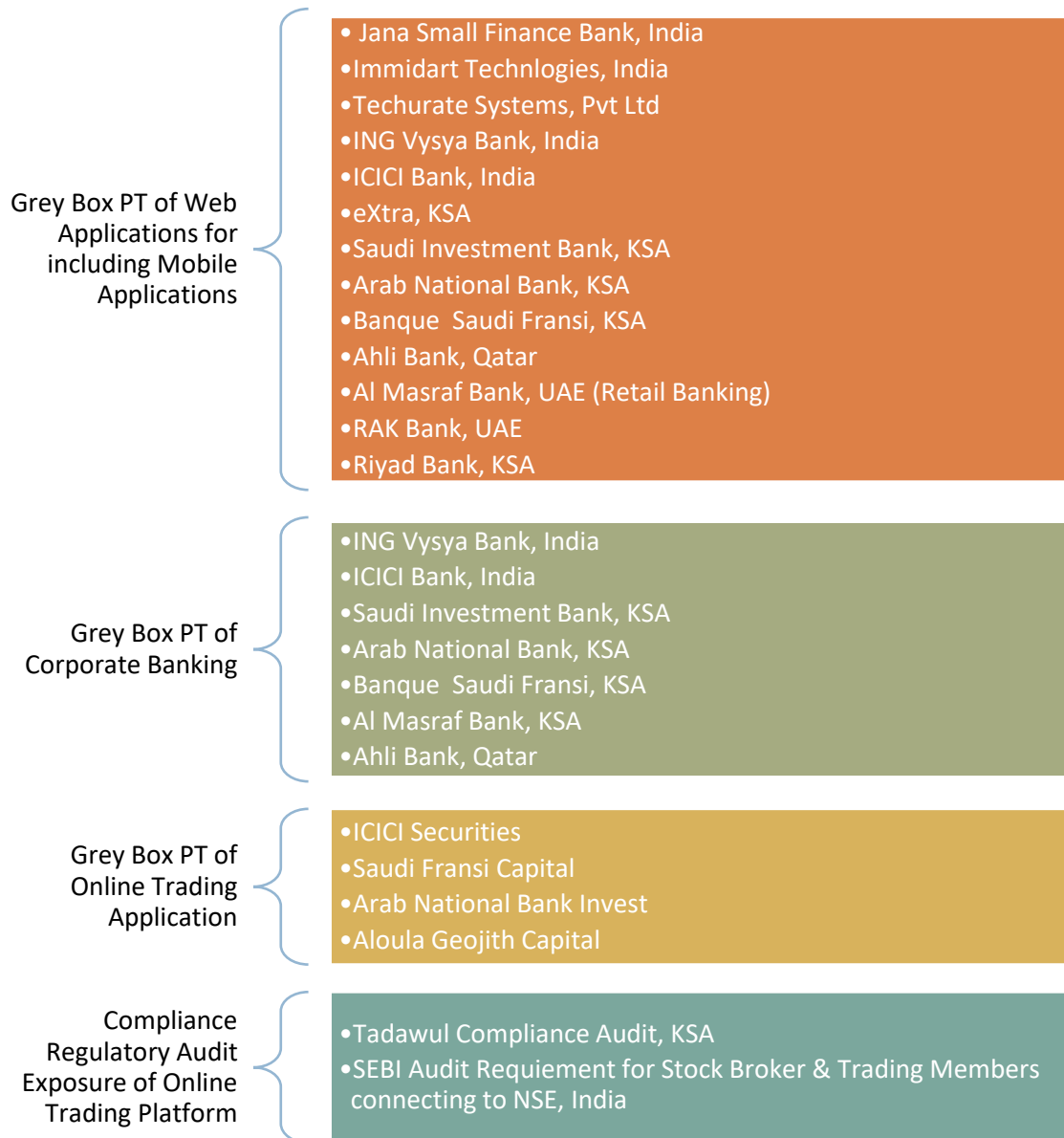
2.1. INTRODUCTION

An Indian Startup founded in April 2006, SecurEyes started with an association with Foundstone (a division of McAfee). SecurEyes has been offering its specialized information security services in the India, Middle East & North Africa. SecurEyes provides the best of breed services offerings with technically sound and experienced consultants.

•2,50,000+ IPs Network PT •29,000+ System VA •12,500+ Application PT •25,000 Users Trained •25,50,000 Lines of Source Code Review •Products Developed for Foundstone (division of McAfee) - HackmeBank, Cookie Digger, WS Digger, .NETValidator & Code Scoping Tool •Inhouse Information Security Products - Hackers Bank, CVMS, VA Scripts, Social Engineering Launcher, Cloud IS training portal Experience Highlight	•eXtra Stores •Janalakshmi Financial Services Ltd •DCB Bank •ING Bank (Kotak) •ICICI Bank •DCB Bank •Mobile Application PT for Techurate Systems PVT Ltd •eXtra, KSA •Riyad Bank, as part of SAMA Assessment, KSA •SAMBA Bank, as part of SAMA Assessment, KSA •GIB, as part of SAMA Assessment, KSA Recent Similar Projects	•Working the Cyber Security Group, Govt. of India for the last 8 years •Certified Auditors - CISA, CCNA, CEH, ISO27001 LA, GCIH •Product Partners - HP, Tenable & McAfee •Authorized Training Partner with EC-Council & Security Innovation •Trusted by Saudi Arabian Monetary Agency (SAMA), KSA •Empanelled with CERT-IN (Awaiting listing on the website) Credibility & Reachability
--	---	---

2.2. RELEVANT EXPERIENCE

We have performed multiple similar projects. Following are the recent customers where such services have been rendered.



2.3. SECUREYES GEOGRAPHIES

SecurEyes has a wide geographic reach in providing specialized information security services. In the last 7 years SecurEyes has successfully expanded the area of its geographical operations from India to regions of:

- ✓ Middle East Asia
 - Dubai
 - Saudi Arabia
 - Qatar
 - Bahrain
- ✓ Oman
 - Muscat
- ✓ United Kingdom
 - London
- ✓ United States of America
- ✓ Africa
 - Sudan
 - Nigeria

It has also expanded the sector reach, initially providing expert security services to Banking/Financial institutions and Government agencies and now successfully including the Telecom and the Logistics sector to name a few.



20+
Banks



10+
Insurance & Trading



5+
Defence Units



300+
Government Depts



5+
Public Sector Units



10+
Health Cares



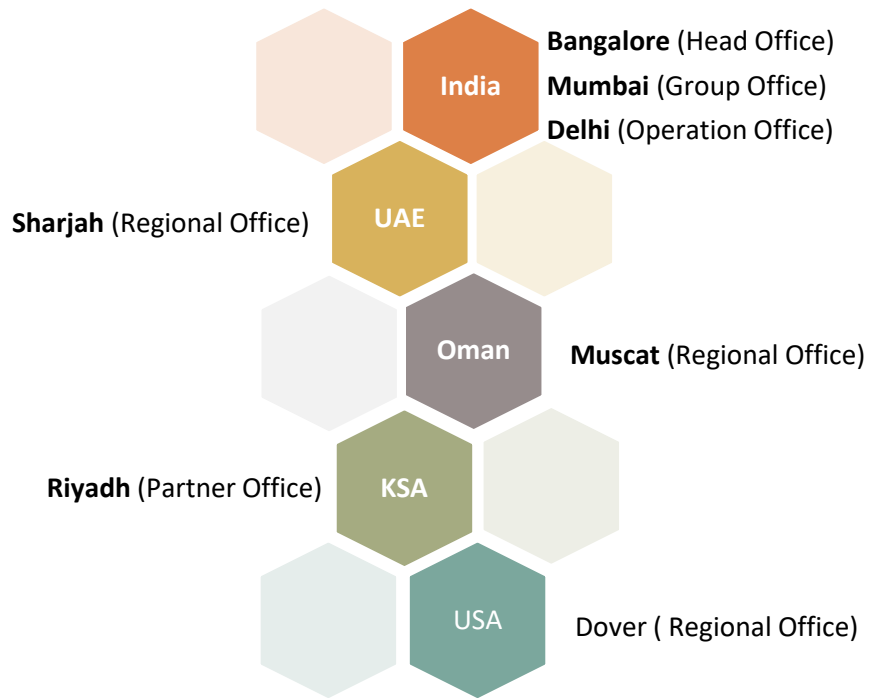
5+
Oil & Gas



150+
Private Organizations

2.4. SECUREYES OFFICES & PARTNERS

SecurEyes has official presence as listed below



2.5. TESTIMONIALS

It was a great pleasure working with you and your team.
The support, performance and professionalism you showed assured ANB that doing business with SecurEyes was a right choice.
Looking forward to working with you in future projects.

Mr. Ala Ibrahim Asali, Dy. Head of Information Security, Compliance Division, Arab National Bank

SecurEyes has been providing us a variety of services in the information security area since 2006 and it has been a great experience working with them all through our engagements. Besides ethical hacking services, we have been availing security consulting services from SecurEyes since 2010. This has helped us doing a detailed analysis of security status of our applications before implementing in production.

Presentation and reporting is a key factor for customer understanding of the security paradigms and jargons. I think SecurEyes have been able to handle this effectively and their reporting formats along with detailed analysis reports are simple to go through, yet precise and clear in the status and expectations. They don't stop with highlighting the risks but also try to help the developer teams with additional inputs for addressing those security issues. This, I feel, is a great value addition that I have not seen coming from larger companies.

Their consultants are experienced, knowledgeable and also very approachable when we really are in need of them. Personally, I see the senior management team of SecurEyes being highly customer focused and I hardly get into situations wherein I need to handle escalations from my team. On the whole, a highly professional organization and are a very good partner to work with and always confidently recommend SecurEyes to anyone

Mr. C.V.G. Prasad, Former Chief Information Officer, ING Vysya Bank

SecurEyes provides a comprehensive training on information security in an engaging manner, which is very well-received by all. It's highly recommended for engineering teams in product security

Mr. Kiran Devaiah, Senior Manager – Product Development, RSA

SecurEyes has provided Safelight Security with expert security and training delivery services for over five years. When Safelight's multi-national customers require in-region delivery of application security training, we are confident that SecurEyes will deliver the most highly qualified professionals. SecurEyes is a Partner in the truest sense and has proven that they can be considered an extended part of our team

Safelight, USA

3. PROJECT SCOPE AND APPROACH

3.1. PROJECT SCOPE

The scope of work activities includes the following:

#	Proposed Project Activity					
1.	Level 1 Application Security Audit of the “SMC, Sambalpur” Application. The following are the details of the application: <table><tr><td>SMC Public Website and CMS module</td></tr><tr><td>20 Pages</td></tr><tr><td>20 Dynamic Pages</td></tr><tr><td>WordPress CMS</td></tr><tr><td>PHP Platform</td></tr></table>	SMC Public Website and CMS module	20 Pages	20 Dynamic Pages	WordPress CMS	PHP Platform
SMC Public Website and CMS module						
20 Pages						
20 Dynamic Pages						
WordPress CMS						
PHP Platform						
2.	Level 2 Compliance check for the application platforms after the issues raised have been fixed					
3.	Final Level Final validation to verify all the reported vulnerabilities have been closed. If site is safe against all well known vulnerabilities, then issuing safe to host certificate to the client.					

3.2. LIST OF ACTIVITIES:

- 3.2.1. One cycle of manual testing covering OWASP standards and other industry best practices
- 3.2.2. Risk rating of observed Risks/Vulnerabilities
- 3.2.3. Providing practical recommendations that can be implemented within the client dynamic environment
- 3.2.4. Preparing detailed audit report with executive summary, detailed finding section & recommendation section
- 3.2.5. One level of retest for the Grey Box Testing to confirm the closure of observed findings/vulnerabilities and final validation
- 3.2.6. Providing clarifications

4. REPORTING & DELIVERABLES

The assessment would include, the following:

#	Components	Deliverables
1.	Report Deliverables	Grey Box Application Penetration Testing of the SMC, Sambalpur - The Report will contain following sections - Executive Summary - Detailed Technical Report with criticality rating - Business impact - Recommendations against each vulnerability

2. DATA REQUIREMENTS

The following details would be required for the execution of project activities:

1. Assignment of a single point of contact for project coordination
2. Accessibility to the applications
3. The below application specific details:
 - a. Enough context specific data in the application for audit purpose
 - b. 2 user credentials for each role
 - c. User Guide, if available
4. Additional data as deemed to be required for the application security audit during the assessment
5. All modules and functionalities should work properly
6. Dummy card details or online dummy banking details for online payment gateway
7. No changes to the code in the environment that is being used for the audit during the assessment period

5. OTHER REQUIREMENTS

1. Work Order / Engagement Letter in favor of "SecurEyes"
2. Assignment of a single point of contact for project coordination
3. Regular assistance from the relevant stake holders for effective completion of the project

6. COST ESTIMATES

The services fee for the above described scope of work would be as presented and described below:

Phase	Module	Onsite/Offsite	Cost (INR)
1	Application Security Audit of the web application platform as listed in the Project Scope Section, two round of compliance check and providing the clearance certificate	Offsite	37,300
Total			37,300.00 (Thirty Seven Thousand Three Hundred Only)

A. TERMS AND CONDITIONS

- Functional testing is not in the scope of this assessment
- The above pricing is valid for a period of 30 days
- The above price is restricted to the scope stated in the technical proposal only and is subjected to due changes for any future deviation in scoping
- GST@ 18% will be charged extra
- The pricing is restricted to the scope stated in the project scope section and is subjected to due changes for any future deviation in scoping
- An amount of 50% of the order value to be released as advance with the Purchase Order
- An amount of 40% of the order value to be released after submission of Level 1 report
- An amount of 10% of the order value to be released after submission clearance certificate.
- The assessment would be carried out from the SecurEyes office in Bangalore
- Any further re-audits will be charged on pro-rata basis.
- The project can start immediately after receipt of the PO and agreement of payment terms

7. ANNEXURE

7.1. ASSESSMENT METHODOLOGY – WEB APPLICATION PEN TESTING METHODOLOGY

7.1.1. INTRODUCTION

An application security assessment is the process of evaluating the strengths and weakness of an application. It also aims at testing the resilience of the application against malicious attacks. The methodology followed at SecurEyes is fool-proof and standardized so that each time the testing is conducted, the result is the same. The process is documented with steps clearly laid out in the test plan. The methodology is a structured process of evaluating the security of an application and application code against malicious hacker attacks with well-defined inputs and outputs in each step of the process. It includes layered deliverables with deliverables in each assessment step. Finally, a consolidated report with executing summary & detailed findings is prepared and submitted.

7.1.2. ASSESSMENT STEPS



7.1.3. DETAILED STEPS

1. Application & Process Understanding

This is the very first step of the application security assessment. The aim of this step is to gain an understanding of the application in the following areas:

- ✓ Understand the application architecture
- ✓ Understand the frameworks being used in the application development
- ✓ Gain information about any specific coding practices followed by the developers
- ✓ Gain an understanding of the security development lifecycle methodology followed by the development team, if any.
- ✓ Understand the various interfacing applications or other interfaces used in the application architecture
- ✓ Determine the purpose of the application from a business perspective
- ✓ Understand the business goals that are fulfilled by the application
- ✓ Gauge the criticality of the application for the business
- ✓ Determine the entry & exit points in the application

Information Required from the Client

1. User, admin, operational guide / other documentation relevant to understand the application
2. Discussion with technical point of contact or application owner for a walk through of various implemented functionalities in the application
3. Deployed application URL along with deployment information for the code
4. Details of User roles & two login credentials for each role
5. Other application documents including architecture documents, low/high level design documents, technical specifications, coding standard guide, end-user guide, admin guide, etc

Activities Performed

1. Gain a thorough understanding of the application using available documentation, application walk through etc.
2. Interaction with Application owner/developers for understanding the various functionalities and services provided by the application
3. Learning the application architecture through review of available documentation
4. Understanding the interfacing and custom communication protocols if any
5. Understanding different application modules

2. Traffic Enumeration

This step involves enumeration of application traffic to help us understand the interaction of the client and server components. The process is to break down the overall application interaction into pairs of requests and responses to perform an in-depth analysis of the traffic. This helps us understand the functionality provided by the application and its implementation on the client/server side from a user perspective.

Activities Performed

1. Gathering traffic transmitting between client and server

2. Figuring out ALL variables/parameters/form fields/hidden variables that are being sent by client onto the server
3. Listing out the exact meaning of each variable to the web application
4. Deriving risks posed by such user inputs
5. Understanding the meaning of any client side enforcements of business rules done by the application

3. Threat Profiling

The primary purpose of preparing a threat profile is to define the Attack Surface (including any third-party or public or backend interfaces) and to list down all possible Threat Agents, threat scenarios that maybe possible. The aim is to also list down all the possible attack scenarios in terms of business impact. The preparation of an application threat profile requires a good understanding of the business purpose of the application. A detailed analysis of all inputs of this phase makes it easy in defining context of the application to establish the business need and purpose of specific functionalities of the application to enterprise. The process also helps to establish the business boundaries of the application context and serves as a mechanism to identify all abuse cases.

This step aims at listing possible threats in terms of business risks to the application. The following are few of the indicative risks for a login application:

- ✓ An attacker can log in without valid user credentials.
- ✓ An attacker can perform an unauthorized operation impersonating an authenticated user.
- ✓ An attacker can upload malicious files on to the server.
- ✓ An attacker can insert malicious scripts into the application leading to the hijacking of the logged-in administrator's session.
- ✓ An attacker can enumerate error messages to get back-end information.
- ✓ An attacker can download the critical web configuration file to get the database user details.
- ✓ One departmental user can manipulate the confidential documents posted in other departments.

Activities Performed

1. Identifying the entry/exit points in the application
2. Identifying all possible business risks
3. Determining the projected impact of each business risks on the business
4. Preparing the Threat Profile

4. Building Testcases

The next step involves building of test cases for exploiting the business risks discovered in the above step. Test cases are built for each of the identified risks. Each of the test cases prepared includes:

- ✓ Page Location (URL / Link)
- ✓ Variables
- ✓ Input value
- ✓ Output value
- ✓ Affected business control

The test cases prepared are based on data collected through enumeration. The test cases adhere to the application security checklist and guidelines including OWASP.

Activities Performed

1. Analyzing the client server traffic based on the possible risks in the threat profile

2. Analyzing the GET/POST parameters
3. Preparing a detailed testcase against each risk in the threat profile

5. Pentest & Verification

The test cases are executed to see if the application is vulnerable to an identified business risk. The auditor can take discretion to alter the logical path of testing if results are interesting. After all the test cases have been executed, the technical risk and business risks are mapped to identify the “real” risks in the application. A thorough verification of the results sieves out the findings which may be a technical risk but are of no business significance. Based on the final findings, we derive the impact of each risk.

Activities Performed

1. Carry out manual audit of all the application modules
2. Carry out exploit simulation for vulnerabilities found in the application modules
3. Documenting the pentest steps alongwith screen shots
4. Computing the DREAD values against each unsafe business risk

6. Reporting

The final step involves preparation of a detailed report which appraises the management of the business risks identified in an application. It also details the technical findings along with the mitigation strategy to help the developers fix the problems. The following are few features of the reports we submit:

- ✓ No false positives
- ✓ Prioritized results
- ✓ Separate executive and technical sections
- ✓ Exposures described in terms of real business risk
- ✓ Resolution resource requirements
- ✓ Real-world recommendations

Activities Performed

1. Preparing a detailed audit report with the following details
 - a. Executive Summary for higher management
 - b. Strengths of the application against known vulnerabilities
 - c. Details of application vulnerabilities/holes discovered
 - d. Step-by-step description of successful exploits
 - e. Mitigation strategies against exploits discovered

END OF DOCUMENT